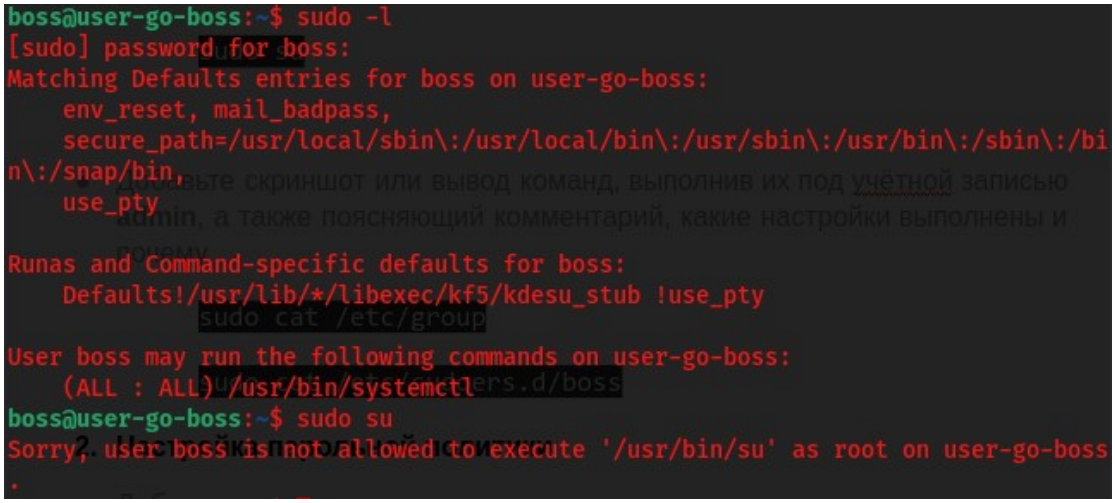
Отчёт о реализации безопасной инфраструктуры в компании «ИнвестПро»

1. Харденинг операционных систем

1. Настройка минимальных привилегий для учётных записей пользователей

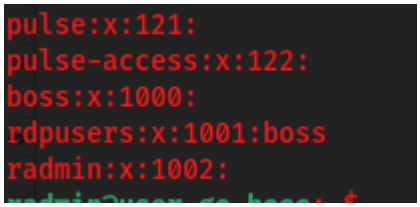
- Добавьте скриншот или вывод команды ниже на компьютере директора по инвестициям (под учётной записью **boss**):

`sudo su`



- Добавьте скриншот или вывод команд, выполнив их под учётной записью **admin**, а также поясняющий комментарий, какие настройки выполнены и почему.

`sudo cat /etc/group`



неудобный скрин, поясняю - босс удален из группы судо

`sudo cat /etc/sudoers.d/boss`

дал боссу только systemctl, но можно было и вообще ничего не давать

```
radmin@user-go-boss:~$ sudo cat /etc/sudoers.d/boss
boss    ALL=(ALL:ALL) /usr/bin/systemctl
```

2. Настройка парольной политики

Добавьте скриншот или вывод команд на компьютере директора по инвестициям:

sudo cat /etc/security/pwquality.conf

sudo cat /etc/login.defs | grep PASS_

sudo cat /etc/pam.d/common-password | grep password

```
GNU nano 6.2                                    /etc/security/pwquality.conf
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 8
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
# dcredit = 0
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
# ucredit = 0
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
# lcredit = 0
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
# ocredit = 0
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
minclass = 3
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
maxrepeat = 3
#
# The maximum number of allowed consecutive characters of the same class in the
# new password.
# The check is disabled if the value is 0
```

```
# Enabled if the option is present.
local_users_only
```

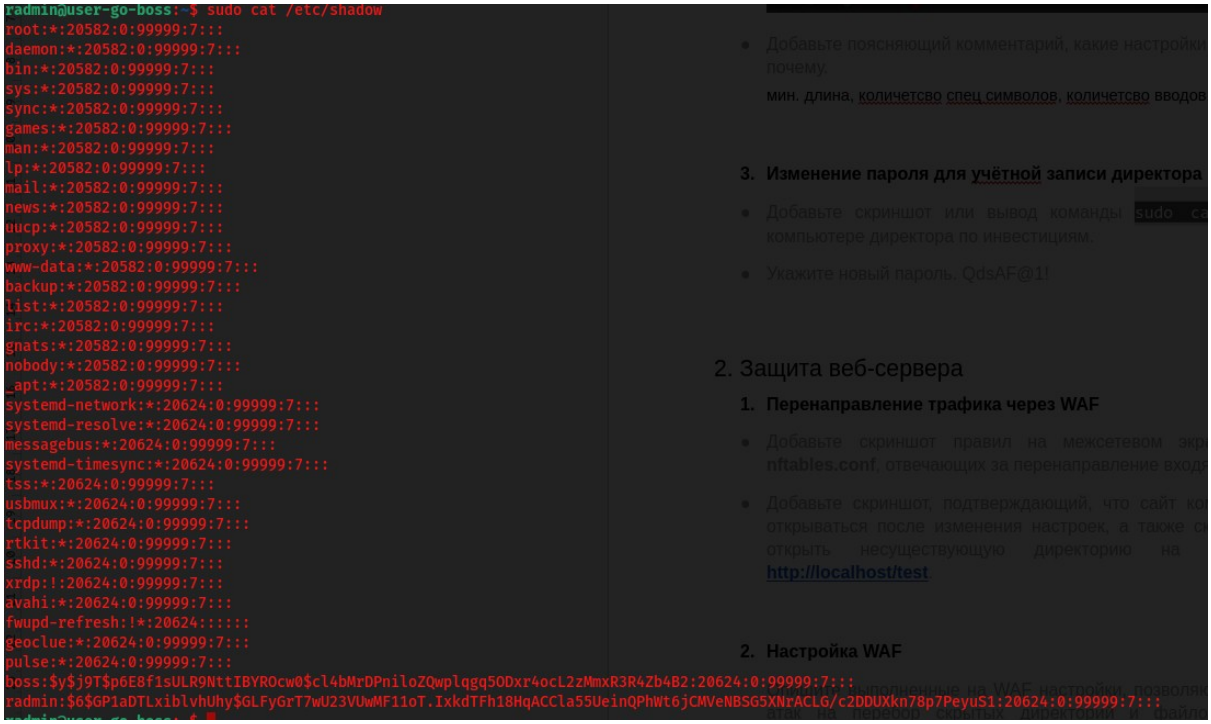
```
radmin@user-go-boss:~$ sudo cat /etc/login.defs | grep PASS_
#       PASS_MAX_DAYS   Maximum number of days a password may be used.
#       PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#       PASS_WARN_AGE   Number of days warning given before a password expires.
PASS_MAX_DAYS   30
PASS_MIN_DAYS   0
PASS_WARN_AGE   7
radmin@user-go-boss:~$ sudo cat /etc/pam.d/common-password | grep password
# /etc/pam.d/common-password - password-related modules common to all services
# used to change user passwords.  The default is pam_unix.
#hashed passwords using the yescrypt algorithm, introduced in Debian
#used the option "sha512"; if a shadow password hash will be shared
password        requisite                       pam_pwquality.so retry=3
password        [success=1 default=ignore]      pam_unix.so obscure use_authtok try_first_pass yescrypt
password        requisite                       pam_deny.so
password        required                        pam_permit.so
radmin@user-go-boss:~$
```

- Добавьте поясняющий комментарий, какие настройки выполнены и почему.

  мин. длина, количетсво спец символов, количетсво вводов, срок жизни пароля

3. Изменение пароля для учётной записи директора по инвестициям

- Добавьте скриншот или вывод команды `sudo cat /etc/shadow` на компьютере директора по инвестициям.

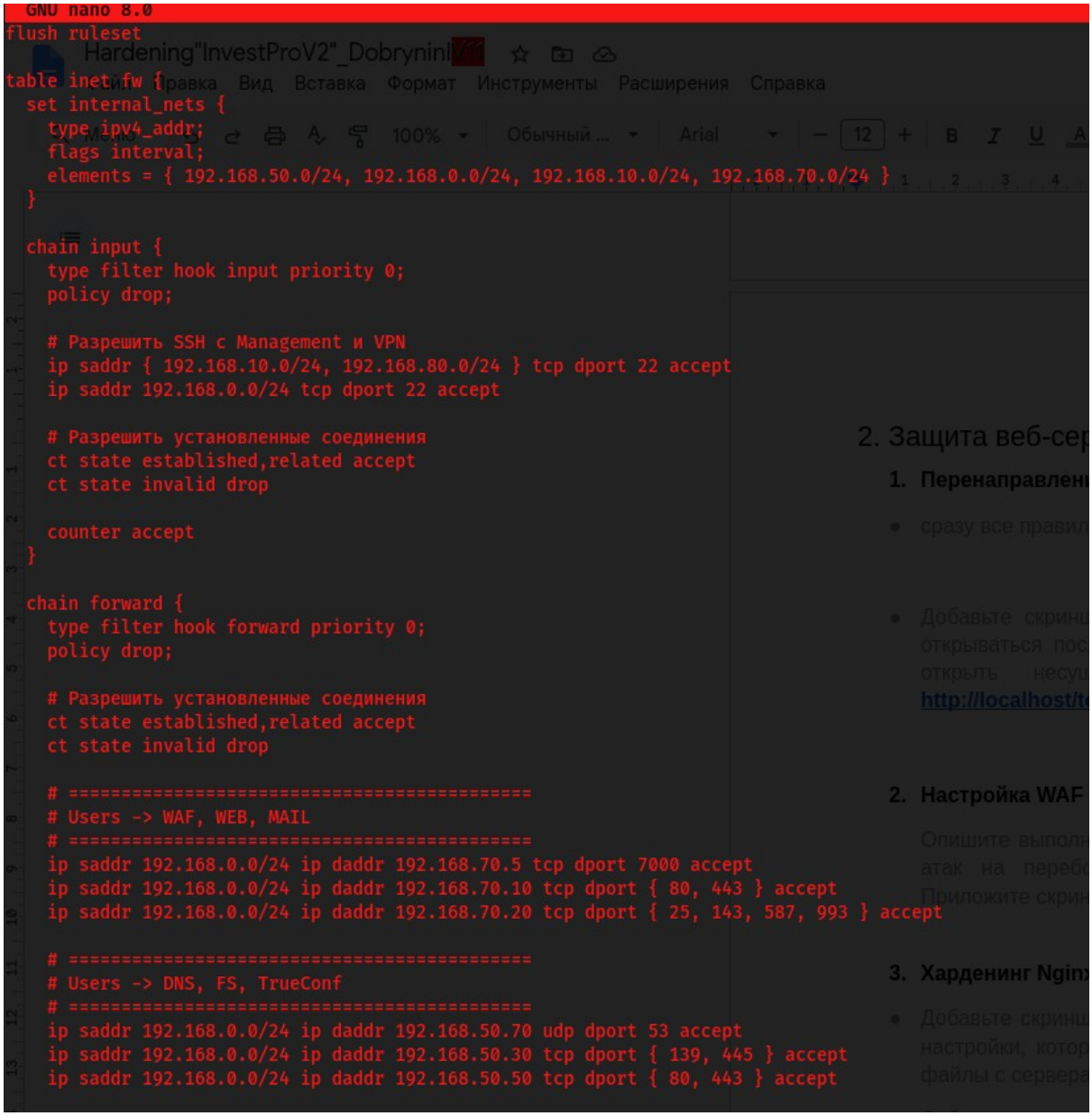


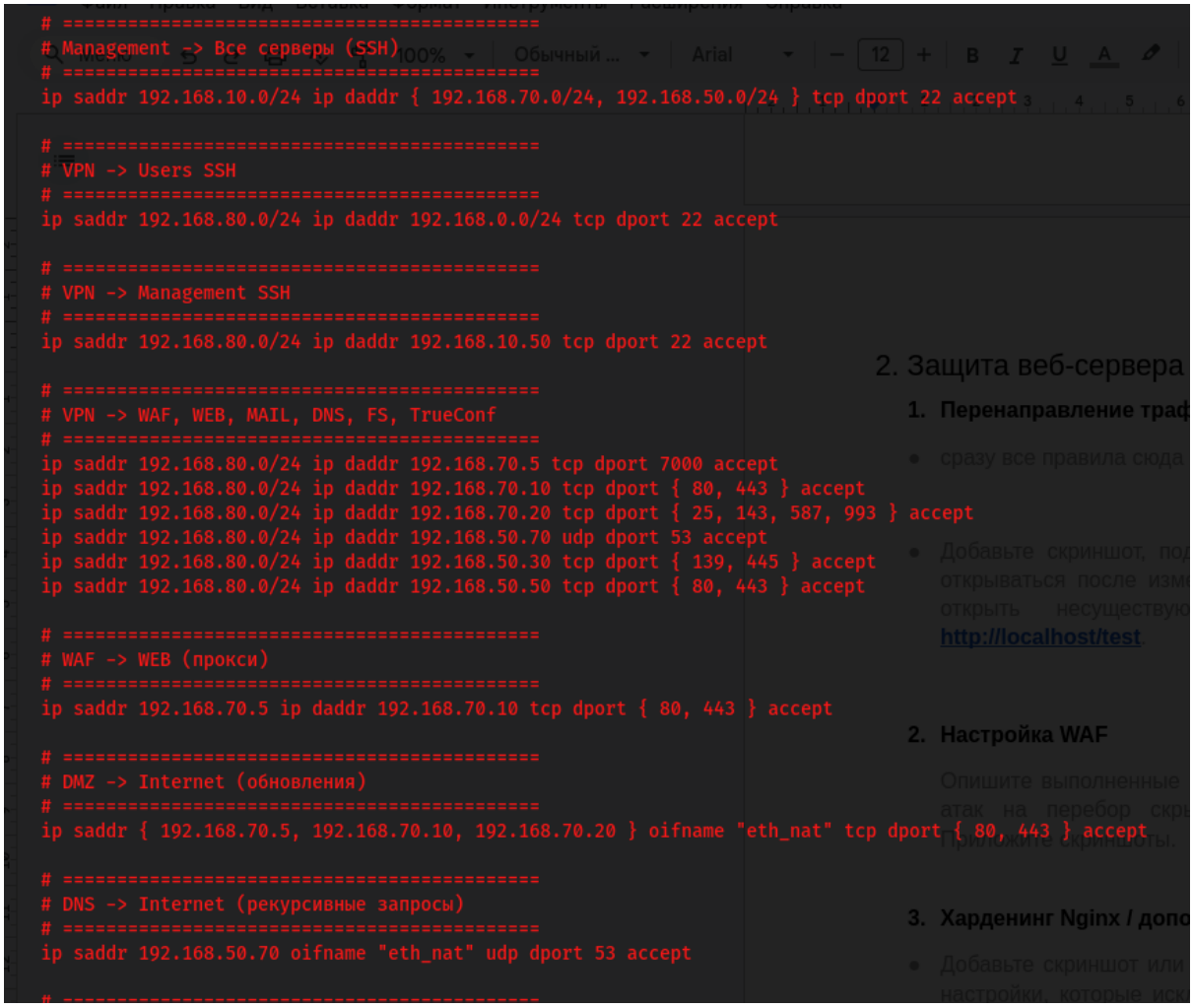
- Укажите новый пароль. QdsAF@1!

2. Защита веб-сервера

1. Перенаправление трафика через WAF

- сразу все правила сюда скину, все сразу прописывал


GNU nano 8.0
flush ruleset
table inet fw {
set internal_nets {
type ipv4_addr;
flags interval;
elements = { 192.168.50.0/24, 192.168.0.0/24, 192.168.10.0/24, 192.168.70.0/24 }
}
chain input {
type filter hook input priority 0;
policy drop;
Разрешить SSH с Management и VPN
ip saddr { 192.168.10.0/24, 192.168.80.0/24 } tcp dport 22 accept
ip saddr 192.168.0.0/24 tcp dport 22 accept
Разрешить установленные соединения
ct state established,related accept
ct state invalid drop
counter accept
}
chain forward {
type filter hook forward priority 0;
policy drop;
Разрешить установленные соединения
ct state established,related accept
ct state invalid drop
==
Users -> WAF, WEB, MAIL
==
ip saddr 192.168.0.0/24 ip daddr 192.168.70.5 tcp dport 7000 accept
ip saddr 192.168.0.0/24 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept
ip saddr 192.168.0.0/24 ip daddr 192.168.70.20 tcp dport { 25, 143, 587, 993 } accept
==
Users -> DNS, FS, TrueConf
==
ip saddr 192.168.0.0/24 ip daddr 192.168.50.70 udp dport 53 accept
ip saddr 192.168.0.0/24 ip daddr 192.168.50.30 tcp dport { 139, 445 } accept
ip saddr 192.168.0.0/24 ip daddr 192.168.50.50 tcp dport { 80, 443 } accept



```
# ==========================================
# Management -> Все серверы (SSH)
# ==========================================
ip saddr 192.168.10.0/24 ip daddr { 192.168.70.0/24, 192.168.50.0/24 } tcp dport 22 accept

# ==========================================
# VPN -> Users SSH
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.0.0/24 tcp dport 22 accept

# ==========================================
# VPN -> Management SSH
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.10.50 tcp dport 22 accept

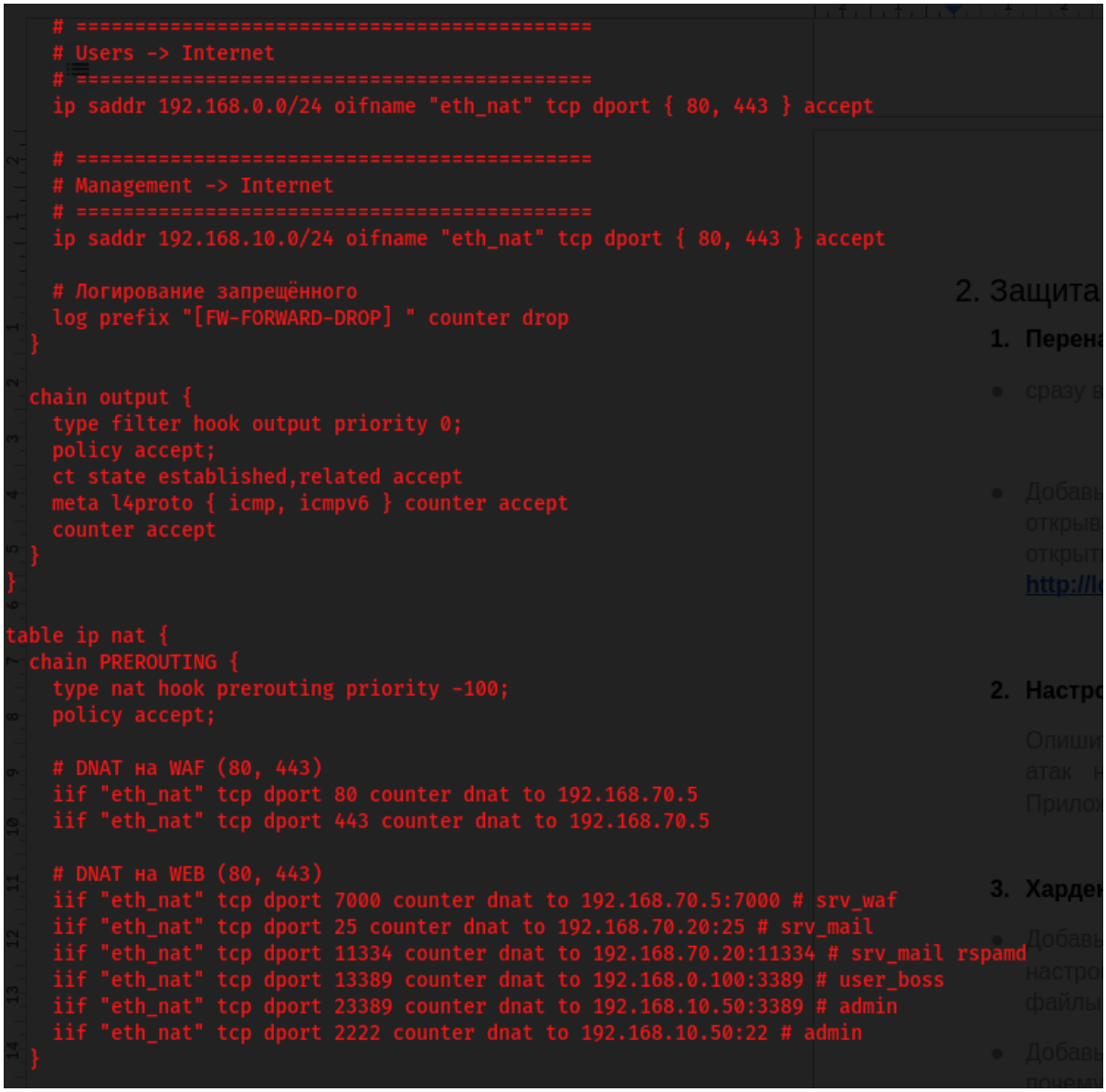
# ==========================================
# VPN -> WAF, WEB, MAIL, DNS, FS, TrueConf
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.70.5 tcp dport 7000 accept
ip saddr 192.168.80.0/24 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.70.20 tcp dport { 25, 143, 587, 993 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.70 udp dport 53 accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.30 tcp dport { 139, 445 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.50 tcp dport { 80, 443 } accept

# ==========================================
# WAF -> WEB (прокси)
# ==========================================
ip saddr 192.168.70.5 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept

# ==========================================
# DMZ -> Internet (обновления)
# ==========================================
ip saddr { 192.168.70.5, 192.168.70.10, 192.168.70.20 } oifname "eth_nat" tcp dport { 80, 443 } accept

# ==========================================
# DNS -> Internet (рекурсивные запросы)
# ==========================================
ip saddr 192.168.50.70 oifname "eth_nat" udp dport 53 accept

# ==========================================
```



```
    # ============================================
    # Users -> Internet
    # ============================================
    ip saddr 192.168.0.0/24 oifname "eth_nat" tcp dport { 80, 443 } accept

    # ============================================
    # Management -> Internet
    # ============================================
    ip saddr 192.168.10.0/24 oifname "eth_nat" tcp dport { 80, 443 } accept

    # Логирование запрещённого
    log prefix "[FW-FORWARD-DROP] " counter drop
  }

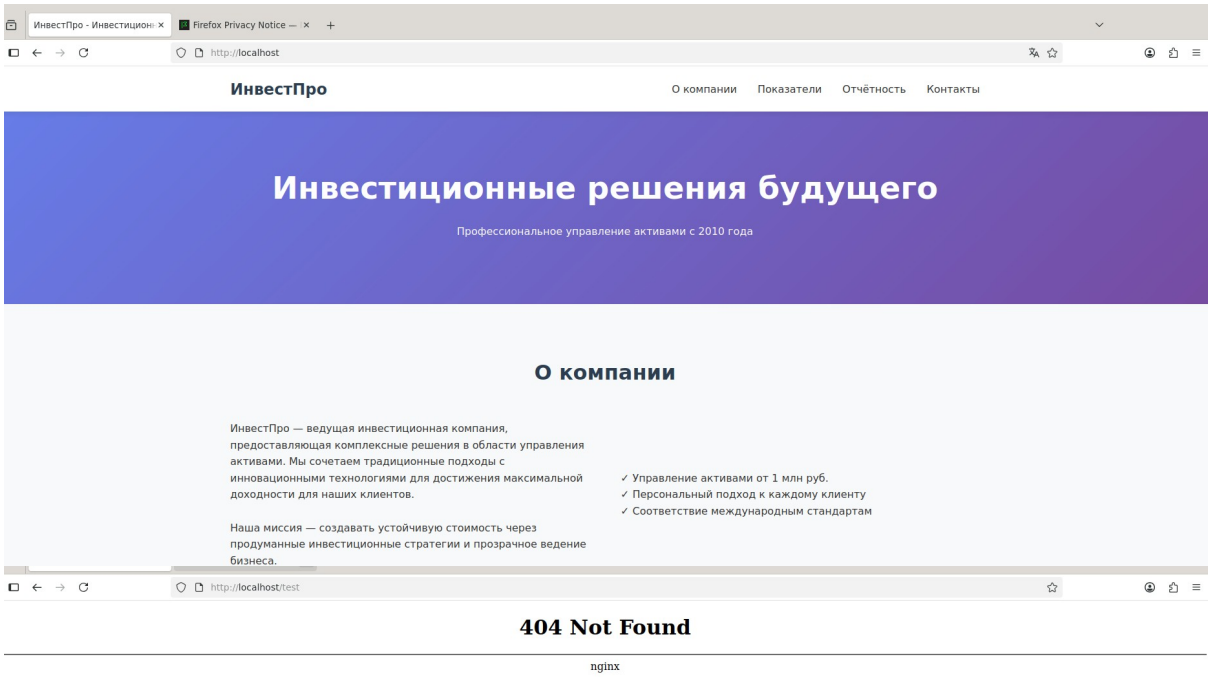
  chain output {
    type filter hook output priority 0;
    policy accept;
    ct state established,related accept
    meta l4proto { icmp, icmpv6 } counter accept
    counter accept
  }
}

table ip nat {
  chain PREROUTING {
    type nat hook prerouting priority -100;
    policy accept;

    # DNAT на WAF (80, 443)
    iif "eth_nat" tcp dport 80 counter dnat to 192.168.70.5
    iif "eth_nat" tcp dport 443 counter dnat to 192.168.70.5

    # DNAT на WEB (80, 443)
    iif "eth_nat" tcp dport 7000 counter dnat to 192.168.70.5:7000 # srv_waf
    iif "eth_nat" tcp dport 25 counter dnat to 192.168.70.20:25 # srv_mail
    iif "eth_nat" tcp dport 11334 counter dnat to 192.168.70.20:11334 # srv_mail rspamd
    iif "eth_nat" tcp dport 13389 counter dnat to 192.168.0.100:3389 # user_boss
    iif "eth_nat" tcp dport 23389 counter dnat to 192.168.10.50:3389 # admin
    iif "eth_nat" tcp dport 2222 counter dnat to 192.168.10.50:22 # admin
  }
```

- Добавьте скриншот, подтверждающий, что сайт компании продолжает открываться после изменения настроек, а также скриншот с попыткой открыть несуществующую директорию на сайте, например, **http://localhost/test**.



2. Настройка WAF

В прекрасной вселенной яндекса не предусмотрено написать пароль от фаервола, правила для работы по критериям ниже

USE_MODSECURITY=yes

USE_CRS=yes

USE_LIMIT_REQ=yes

LIMIT_REQ_RATE=30r/m

USE_BAD_BEHAVIOR=yes

BAD_BEHAVIOR_STATUS_CODES="404"

BAD_BEHAVIOR_BAN_TIME=300

3. Харденинг Nginx / дополнительные правила WAF

- Добавьте скриншот или вывод команды, подтверждающие выполненные настройки, которые исключают возможность получить критично важные файлы с сервера через отображение запросов к **/log/**.

```
erver {
    listen 80 default_server;
    server_name site.local;

    root /usr/share/nginx/html;
    index index.html;

    location / {
        try_files $uri $uri/ =404;
    }

    # Запрет доступа к служебным директориям
    location ~ /(log|backup|robots.txt|temp|tmp|storage|cache) {
        deny all;
        return 404;
    }

    # Запрет доступа к файлам с конфигами, логами, хэшами
    location ~* \.(log|txt|sql|bak|old|conf|ini|hash|pwd|pass|secret)$ {
        deny all;
        return 404;
    }

    # Запрет доступа к скрытым файлам
    location ~ /\. {
        deny all;
        return 404;
    }

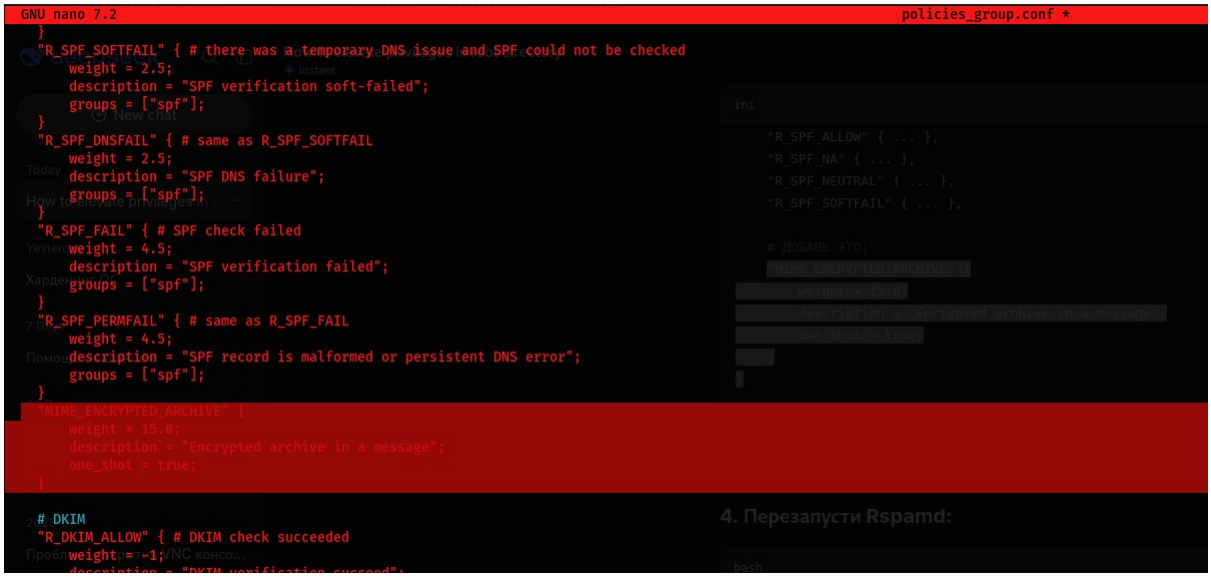
    # Исключение для .well-known (нужен для SSL)
    location ~ /\.well-known {
        allow all;
    }

    # Скрыть версию nginx
    server_tokens off;
}
    location /log/ {
        alias /;
        autoindex on;
        autoindex_exact_size off;
        autoindex_localtime on;
        sendfile on;
        try_files $uri =404;
    }
}
```

- Добавьте поясняющий комментарий, какие настройки выполнены и почему.

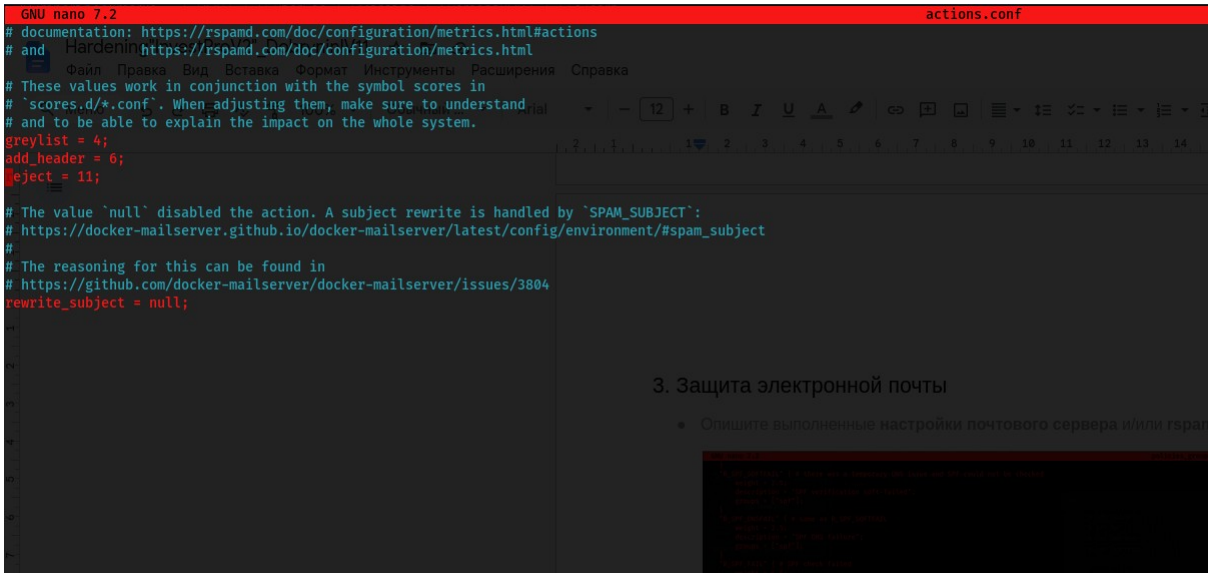
3. Защита электронной почты

- Опишите выполненные **настройки почтового сервера** и/или **rspamd**.



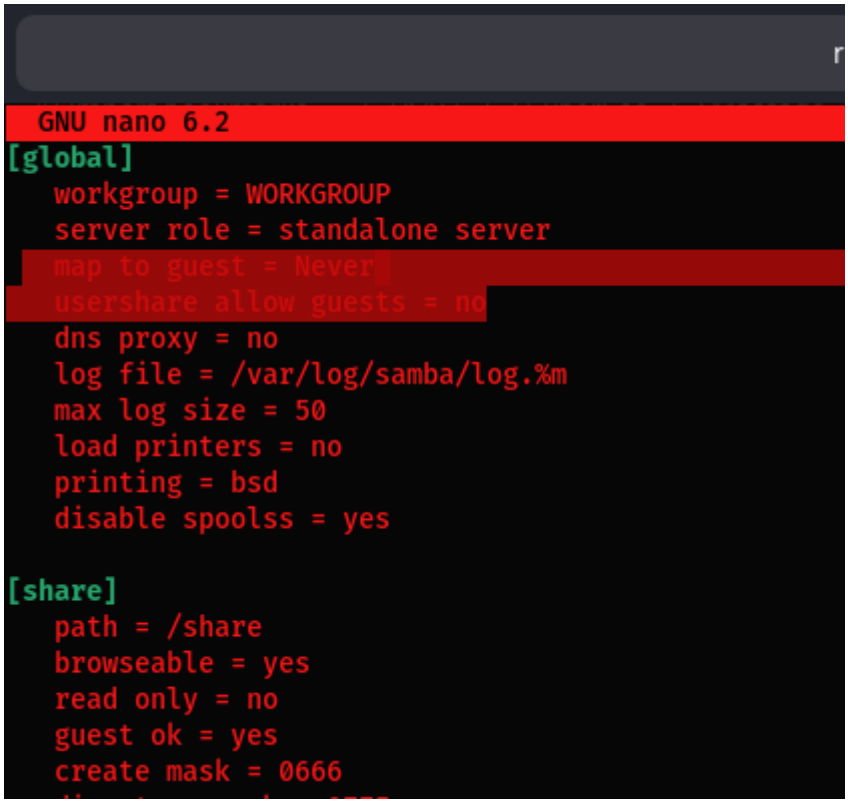
Добавил 15 баллов на запароленные архивы

в файле actions reject от 11 баллов, письмо не будет доставлено



4. Защита файловых ресурсов: харденинг Samba и разграничение доступа

- Добавьте скриншот или вывод команды с выполненными настройками **Samba** на файловом сервере `cat /etc/samba/smb.conf` или скопируйте из терминала целиком команду и результат её работы.


GNU nano 6.2
[global]
workgroup = WORKGROUP
server role = standalone server
map to guest = Never
usershare allow guests = no
dns proxy = no
log file = /var/log/samba/log.%m
max log size = 50
load printers = no
printing = bsd
disable spoolss = yes
[share]
path = /share
browseable = yes
read only = no
guest ok = yes
create mask = 0666

```
[top_management]
    comment = Стратегия компании
    path = /srv/samba/top_management
    browseable = yes
    read only = no
    valid users = @top_management
    write list = @top_management
    create mask = 0660
    directory mask = 2770
    force group = top_management
    guest ok = no

[Managers]
    comment = Отчёты
    path = /srv/samba/managers
    browseable = yes
    read only = no
    valid users = @top_management, @managers
    write list = @top_management, @managers
    create mask = 0660
    directory mask = 2770
    force group = managers
    guest ok = no

[Analytics]
    comment = Клиентская информация
    path = /srv/samba/analytics
    browseable = yes
    read only = no
    valid users = @top_management, @analytics
    write list = @top_management, @analytics
    create mask = 0660
    directory mask = 2770
    force group = analytics
    guest ok = no

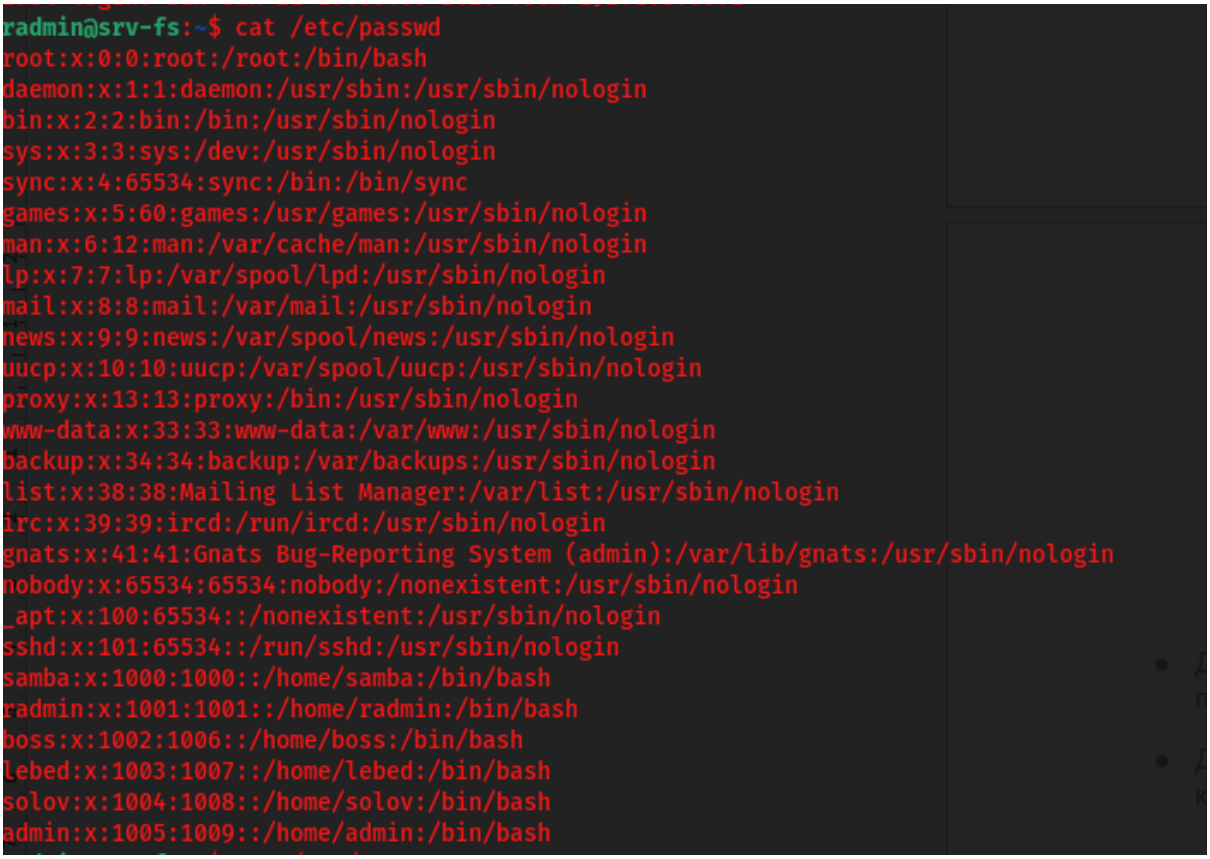
[IT]
    comment = Администрирование
    path = /srv/samba/it
    browseable = yes
    read only = no
    valid users = @it
    write list = @it
    create mask = 0660
    directory mask = 2770
    force group = it
    guest ok = no
```

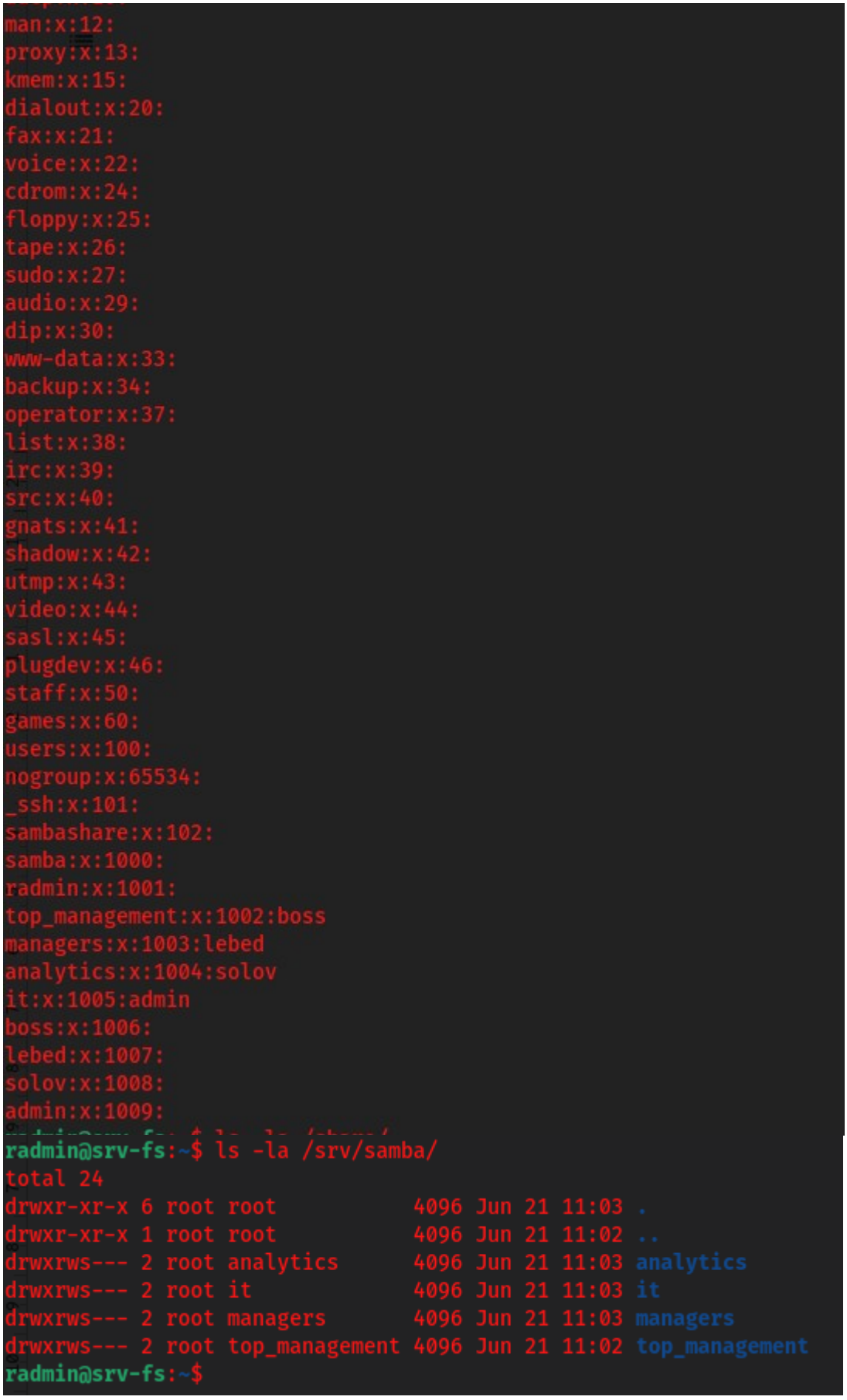
- Добавьте скриншот или вывод команд:

```
cat /etc/passwd
```

```
cat /etc/group
```

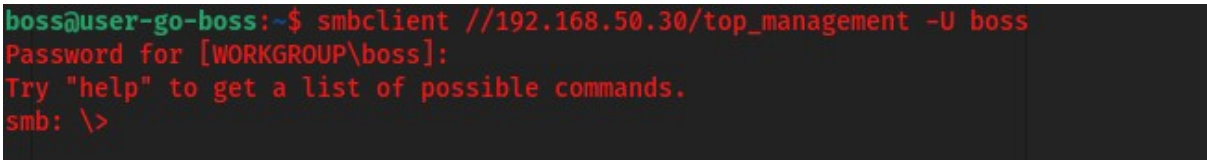
```
ls -la /share/
```


radmin@srv-fs:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
samba:x:1000:1000::/home/samba:/bin/bash
radmin:x:1001:1001::/home/radmin:/bin/bash
boss:x:1002:1006::/home/boss:/bin/bash
lebed:x:1003:1007::/home/lebed:/bin/bash
solov:x:1004:1008::/home/solov:/bin/bash
admin:x:1005:1009::/home/admin:/bin/bash


man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:
fax:x:21:
voice:x:22:
cdrom:x:24:
floppy:x:25:
tape:x:26:
sudo:x:27:
audio:x:29:
dip:x:30:
www-data:x:33:
backup:x:34:
operator:x:37:
list:x:38:
irc:x:39:
src:x:40:
gnats:x:41:
shadow:x:42:
utmp:x:43:
video:x:44:
sasl:x:45:
plugdev:x:46:
staff:x:50:
games:x:60:
users:x:100:
nogroup:x:65534:
_ssh:x:101:
sambashare:x:102:
samba:x:1000:
radmin:x:1001:
top_management:x:1002:boss
managers:x:1003:lebed
analytics:x:1004:solov
it:x:1005:admin
boss:x:1006:
lebed:x:1007:
solov:x:1008:
admin:x:1009:
radmin@srv-fs:~$ ls -la /srv/samba/
total 24
drwxr-xr-x 6 root root 4096 Jun 21 11:03 .
drwxr-xr-x 1 root root 4096 Jun 21 11:02 ..
drwxrws--- 2 root analytics 4096 Jun 21 11:03 analytics
drwxrws--- 2 root it 4096 Jun 21 11:03 it
drwxrws--- 2 root managers 4096 Jun 21 11:03 managers
drwxrws--- 2 root top_management 4096 Jun 21 11:02 top_management
radmin@srv-fs:~$

- Добавьте скриншот проверки подключения к файловым ресурсам с компьютера директора по инвестициям после настройки прав:

  `smbclient //192.168.50.30/Share -U boss`

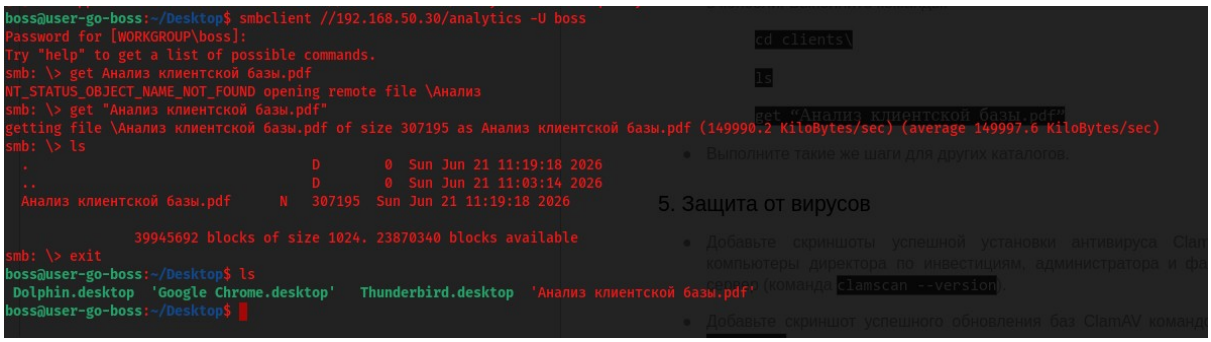


- Введите пароль от учётной записи **boss** и после подключения работайте в консоли. Выполните команды:

  `cd clients\`

  `ls`

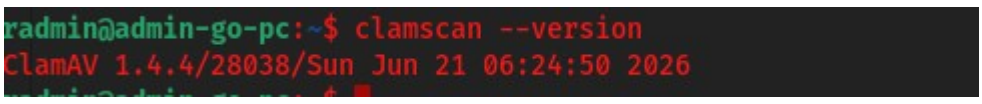
  `get “Анализ клиентской базы.pdf”`

- 

- Я настраивал на другую папку шару, поэтому перенес файл в свою папку аналитики и гетнул на боссе.

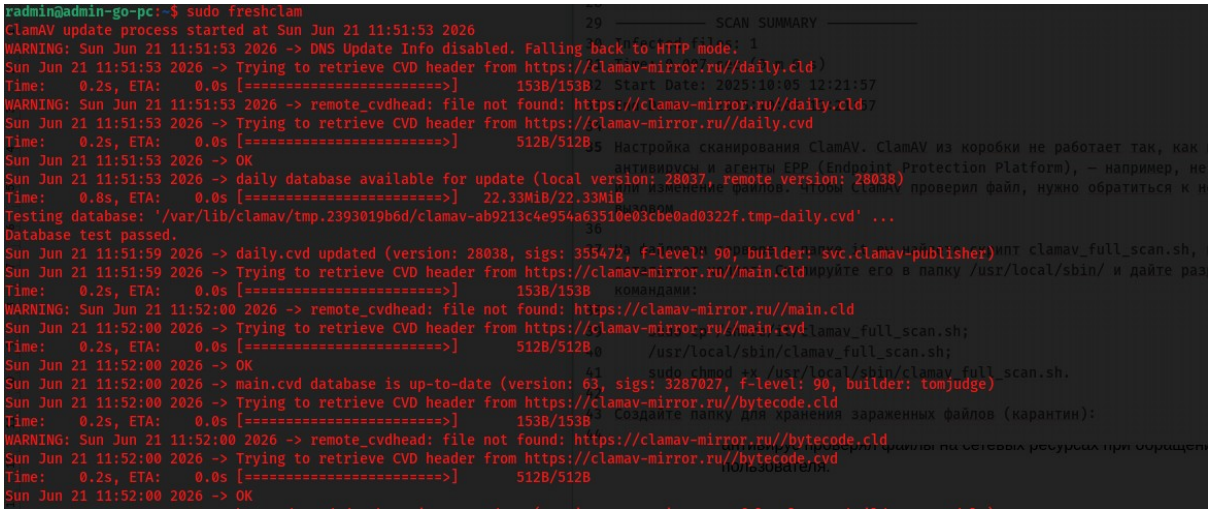
5. Защита от вирусов

- Добавьте скриншоты успешной установки антивируса ClamAV на компьютеры директора по инвестициям, администратора и файловый сервер (команда `clamscan --version`).

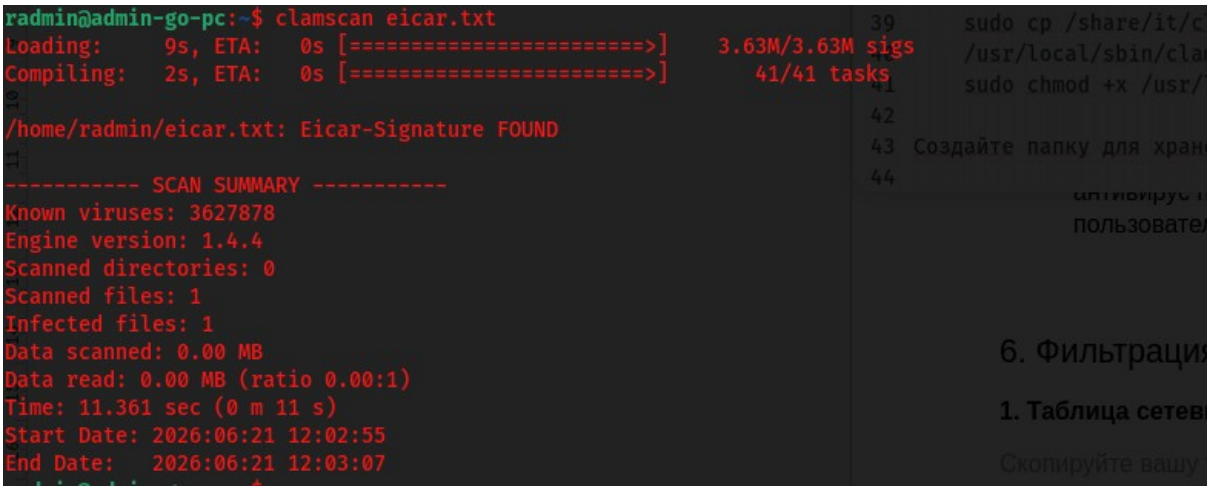


не нашел решения проблемы, поэтому дальнейшие действия невозможны, на обоих компьютерах он заблокировал мне и все.

- Добавьте скриншот успешного обновления баз ClamAV командой `sudo freshclam`.



- Добавьте скриншот успешного обнаружения вируса в файле **EICAR** командой `clamscan`, выполненной в директории с файлом.



- Реализуйте интеграцию **ClamAV** с **samba** на файловом сервере, чтобы антивирус проверял файлы на сетевых ресурсах при обращении к ним пользователя.

6. Фильтрация трафика

1. Таблица сетевых потоков

Скопируйте вашу таблицу сетевых потоков из отчёта по первой части проектной работы и дополните её столбцом «Правила nftables» по аналогии с примером ниже. Старайтесь формировать правила с учётом принципа нулевого доверия.

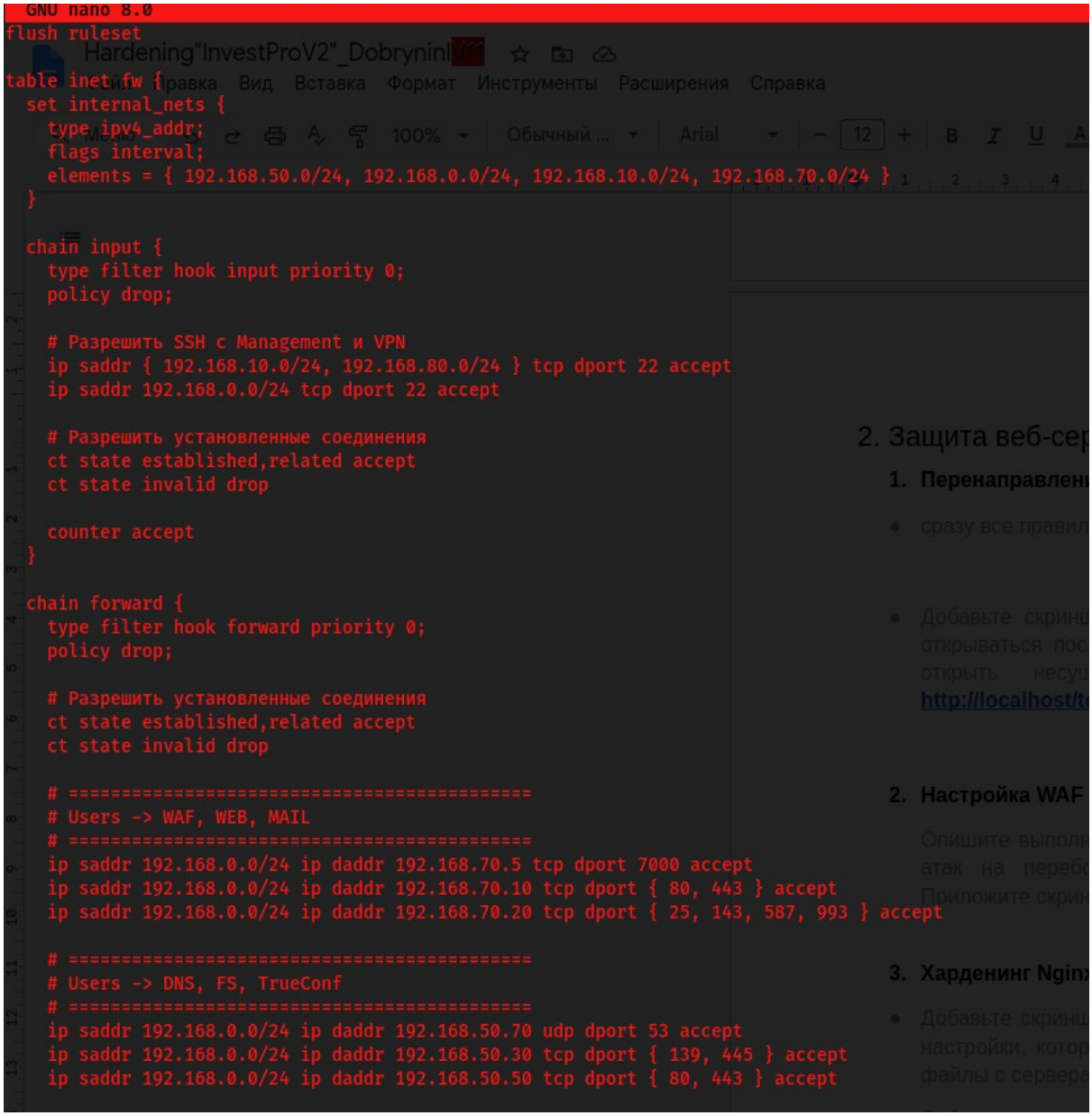
Описание потока	Исходящий/ входящий	Откуда (IP-адрес/подсеть)	Куда (IP-адрес/подсеть)	Порты и протоколы

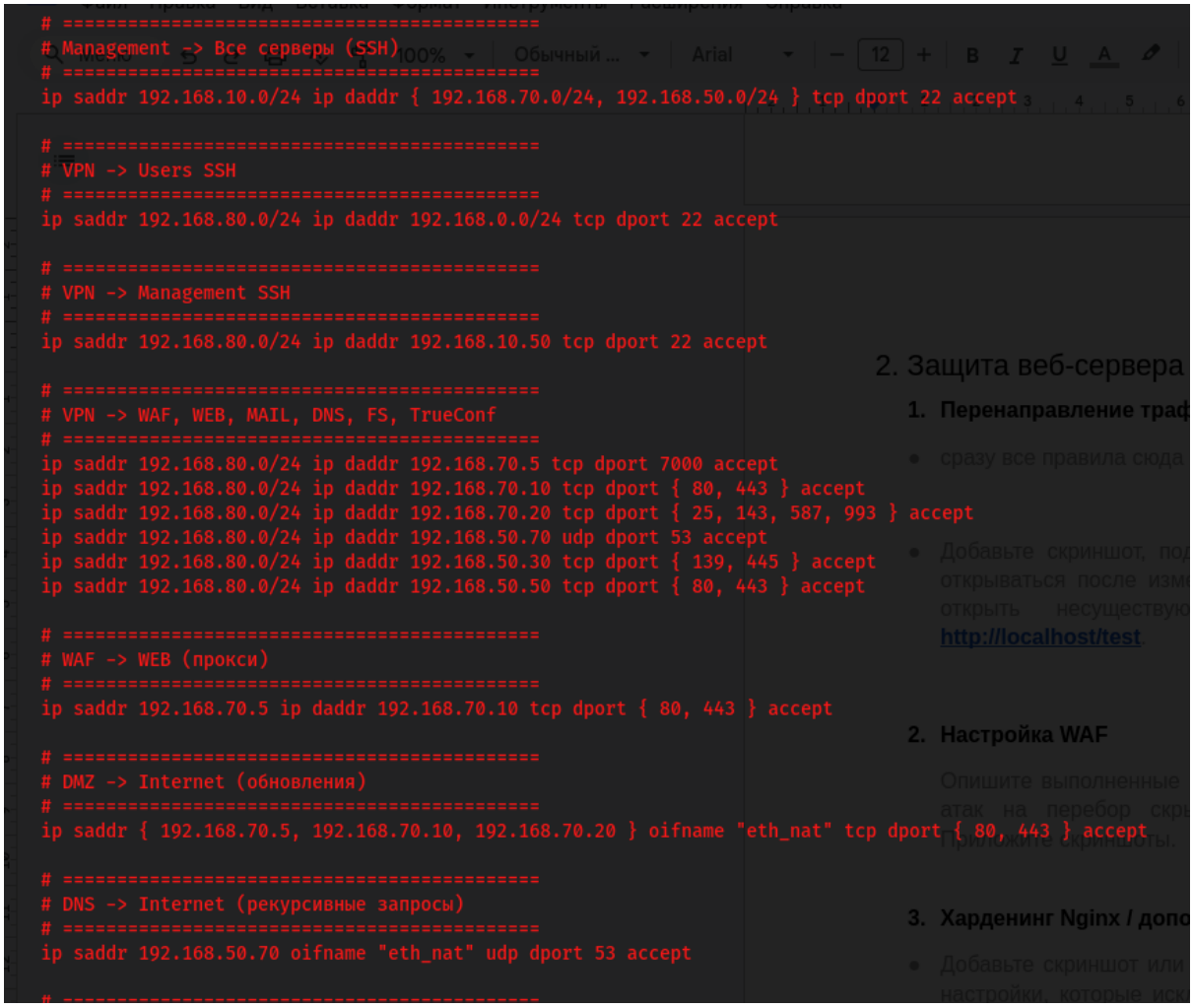
WAF (server-waf - 192.168.70.5)				
Перенаправление трафика на WAF (DNAT)	Входящий	Internet (любой)	FW (192.168.0.254) → DNAT → server-waf (192.168.70.5)	HTTP (TCP 80), HTTPS (TCP 443)
Проксирование от WAF к веб-серверу	Исходящий	server-waf (192.168.70.5)	server-web (192.168.70.10)	HTTP (TCP 80), HTTPS (TCP 443)
Администрирование WAF	Исходящий	Management (192.168.10.0/24)	server-waf (192.168.70.5)	SSH (TCP 22)
Веб-сервер (server-web - 192.168.70.10)				
Из интернета (через WAF)	Входящий	WAF (192.168.70.5) → server-web	server-web (192.168.70.10)	HTTP (TCP 80), HTTPS (TCP 443)
Пользователи к веб-сайту	Исходящий	Users (192.168.0.0/24)	server-web (192.168.70.10)	HTTP (TCP 80), HTTPS (TCP 443)
Администрирование веб-сервера	**Исходящий**	**Management (192.168.10.0/24)**	**server-web (192.168.70.10)**	**SSH (TCP 22)**
Выход в интернет (обновления)	Исходящий	server-web (192.168.70.10)	Internet (любой)	HTTP (TCP 80), HTTPS (TCP 443)
Электронная почта (server-mail - 192.168.70.20)				
Получение почты	**Входящий**	**Internet (любой)**	**server-mail (192.168.70.20)**	**SMTP (TCP 25)**
Получение почты (IMAP)	Исходящий	Users (192.168.0.0/24)	server-mail (192.168.70.20)	IMAP (TCP 143)
Получение почты (IMAPS)	Исходящий	Users (192.168.0.0/24)	server-mail (192.168.70.20)	IMAPS (TCP 993)
Отправка почты	Исходящий	Users (192.168.0.0/24)	server-mail (192.168.70.20)	SMTP (TCP 587)
Администрирование почты	Исходящий	Management (192.168.10.0/24)	server-mail (192.168.70.20)	SSH (TCP 22)
DNS-сервер (server-dns - 192.168.50.70)				
DNS-запросы от Users	Исходящий	Users (192.168.0.0/24)	server-dns (192.168.50.70)	DNS (UDP/TCP 53)
DNS-запросы от DMZ	Исходящий	DMZ (192.168.70.0/24)	server-dns (192.168.50.70)	DNS (UDP/TCP 53)
DNS-запросы от Management	Исходящий	Management (192.168.10.0/24)	server-dns (192.168.50.70)	DNS (UDP/TCP 53)

DNS-запросы от VPN	Исходящий	VPN (192.168.80.0/24)	server-dns (192.168.50.70)	DNS (UDP/TCP 53)
Рекурсивные запросы в интернет	Исходящий	server-dns (192.168.50.70)	Internet (любой)	DNS (UDP/TCP 53)
Администрирование DNS	Исходящий	Management (192.168.10.0/24)	server-dns (192.168.50.70)	SSH (TCP 22)
Файловый сервер (server-fs - 192.168.50.30)				
Доступ к файлам (Users)	Исходящий	Users (192.168.0.0/24)	server-fs (192.168.50.30)	SMB (TCP 139, 445)
Доступ к файлам (Management)	Исходящий	Management (192.168.10.0/24)	server-fs (192.168.50.30)	SMB (TCP 139, 445)
Доступ к файлам (VPN)	Исходящий	VPN (192.168.80.0/24)	server-fs (192.168.50.30)	SMB (TCP 139, 445)
Администрирование файлового сервера	Исходящий	Management (192.168.10.0/24)	server-fs (192.168.50.30)	SSH (TCP 22)
TrueConf (server-trueconf - 192.168.50.50)				
Видеоконференции (Users)	Исходящий	Users (192.168.0.0/24)	server-trueconf (192.168.50.50)	TCP/UDP (TrueConf)
Видеоконференции (VPN)	Исходящий	VPN (192.168.80.0/24)	server-trueconf (192.168.50.50)	TCP/UDP (TrueConf)
Администрирование TrueConf	Исходящий	Management (192.168.10.0/24)	server-trueconf (192.168.50.50)	SSH (TCP 22)
VPN-сервер (server-vpn - 192.168.80.5)				
Подключение удаленных сотрудников	Входящий	Internet (удаленные пользователи)	server-vpn (192.168.80.5)	VPN (UDP 51820/1194)
Пользовательский сегмент (Users - 192.168.0.0/24)				
Выход в интернет (Users)	Исходящий	Users (192.168.0.0/24)	Internet (любой)	HTTP (TCP 80), HTTPS (TCP 443)
Административный сегмент (Management - 192.168.10.0/24)				
Выход в интернет (Management)	Исходящий	Management (192.168.10.0/24)	Internet (любой)	HTTP (TCP 80), HTTPS (TCP 443)

SSH-доступ удаленных пользователей (через VPN)				
Подключение к user-go-boss	Входящий	VPN (192.168.80.0/24)	user-go-boss (192.168.0.100)	SSH (TCP 22)
Подключение к user-go-lebed	Входящий	VPN (192.168.80.0/24)	user-go-lebed (192.168.0.10)	SSH (TCP 22)
Подключение к user-go-solov	Входящий	VPN (192.168.80.0/24)	user-go-solov (192.168.0.20)	SSH (TCP 22)
Подключение к admin-go-pc	Входящий	VPN (192.168.80.0/24)	admin-go-pc (192.168.10.50)	SSH (TCP 22)
Общие правила				
SSH-доступ ко всем серверам	Исходящий	Management (192.168.10.0/24)	Все серверы (DMZ и Servers)	SSH (TCP 22)
SSH-доступ через VPN	Исходящий	VPN (192.168.80.0/24)	Все серверы (DMZ и Servers)	SSH (TCP 22)

2. Конфигурация межсетевого экрана


GNU nano 8.0
flush ruleset
table inet fw {
set internal_nets {
type ipv4_addr;
flags interval;
elements = { 192.168.50.0/24, 192.168.0.0/24, 192.168.10.0/24, 192.168.70.0/24 }
}
chain input {
type filter hook input priority 0;
policy drop;
Разрешить SSH с Management и VPN
ip saddr { 192.168.10.0/24, 192.168.80.0/24 } tcp dport 22 accept
ip saddr 192.168.0.0/24 tcp dport 22 accept
Разрешить установленные соединения
ct state established,related accept
ct state invalid drop
counter accept
}
chain forward {
type filter hook forward priority 0;
policy drop;
Разрешить установленные соединения
ct state established,related accept
ct state invalid drop
==
Users -> WAF, WEB, MAIL
==
ip saddr 192.168.0.0/24 ip daddr 192.168.70.5 tcp dport 7000 accept
ip saddr 192.168.0.0/24 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept
ip saddr 192.168.0.0/24 ip daddr 192.168.70.20 tcp dport { 25, 143, 587, 993 } accept
==
Users -> DNS, FS, TrueConf
==
ip saddr 192.168.0.0/24 ip daddr 192.168.50.70 udp dport 53 accept
ip saddr 192.168.0.0/24 ip daddr 192.168.50.30 tcp dport { 139, 445 } accept
ip saddr 192.168.0.0/24 ip daddr 192.168.50.50 tcp dport { 80, 443 } accept



```
# ==========================================
# Management -> Все серверы (SSH)
# ==========================================
ip saddr 192.168.10.0/24 ip daddr { 192.168.70.0/24, 192.168.50.0/24 } tcp dport 22 accept

# ==========================================
# VPN -> Users SSH
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.0.0/24 tcp dport 22 accept

# ==========================================
# VPN -> Management SSH
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.10.50 tcp dport 22 accept

# ==========================================
# VPN -> WAF, WEB, MAIL, DNS, FS, TrueConf
# ==========================================
ip saddr 192.168.80.0/24 ip daddr 192.168.70.5 tcp dport 7000 accept
ip saddr 192.168.80.0/24 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.70.20 tcp dport { 25, 143, 587, 993 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.70 udp dport 53 accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.30 tcp dport { 139, 445 } accept
ip saddr 192.168.80.0/24 ip daddr 192.168.50.50 tcp dport { 80, 443 } accept

# ==========================================
# WAF -> WEB (прокси)
# ==========================================
ip saddr 192.168.70.5 ip daddr 192.168.70.10 tcp dport { 80, 443 } accept

# ==========================================
# DMZ -> Internet (обновления)
# ==========================================
ip saddr { 192.168.70.5, 192.168.70.10, 192.168.70.20 } oifname "eth_nat" tcp dport { 80, 443 } accept

# ==========================================
# DNS -> Internet (рекурсивные запросы)
# ==========================================
ip saddr 192.168.50.70 oifname "eth_nat" udp dport 53 accept

# ==========================================
```

```
    # ============================================
    # Users -> Internet
    # ============================================
    ip saddr 192.168.0.0/24 oifname "eth_nat" tcp dport { 80, 443 } accept

    # ============================================
    # Management -> Internet
    # ============================================
    ip saddr 192.168.10.0/24 oifname "eth_nat" tcp dport { 80, 443 } accept

    # Логирование запрещённого
    log prefix "[FW-FORWARD-DROP] " counter drop
  }

  chain output {
    type filter hook output priority 0;
    policy accept;
    ct state established,related accept
    meta l4proto { icmp, icmpv6 } counter accept
    counter accept
  }
}

table ip nat {
  chain PREROUTING {
    type nat hook prerouting priority -100;
    policy accept;

    # DNAT на WAF (80, 443)
    iif "eth_nat" tcp dport 80 counter dnat to 192.168.70.5
    iif "eth_nat" tcp dport 443 counter dnat to 192.168.70.5

    # DNAT на WEB (80, 443)
    iif "eth_nat" tcp dport 7000 counter dnat to 192.168.70.5:7000 # srv_waf
    iif "eth_nat" tcp dport 25 counter dnat to 192.168.70.20:25 # srv_mail
    iif "eth_nat" tcp dport 11334 counter dnat to 192.168.70.20:11334 # srv_mail rspamd
    iif "eth_nat" tcp dport 13389 counter dnat to 192.168.0.100:3389 # user_boss
    iif "eth_nat" tcp dport 23389 counter dnat to 192.168.10.50:3389 # admin
    iif "eth_nat" tcp dport 2222 counter dnat to 192.168.10.50:22 # admin
  }
```

поскольку пока что нет ВПН, я еще добавил строки в цепочку форвард #DMZ из инета

iifname "eth_nat" ip daddr 192.168.70.5 tcp dport 7000 accept

iifname "eth_nat" ip daddr 192.168.70.10 tcp dport { 80, 443 } accept

iifname "eth_nat" ip daddr 192.168.70.20 tcp dport { 25, 143, 587, 993 } accept

3. Доступность сервисов из интернета

- После применения правил МСЭ добавьте скриншот или скопируйте вывод команд, выполненных на хосте с Ubuntu.

  `nmap -Pn -n -p- -sT -sV --script=banner --script-timeout 30s --max-retries 0 127.0.0.1`

```
PORT      STATE SERVICE
22/tcp    open  ssh
|_banner: SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.14
25/tcp    open  smtp
80/tcp    open  http
2222/tcp  open  EtherNetIP-1
3389/tcp  open  ms-wbt-server
```

`curl http://localhost -I`

HTTP/1.1 200 OK

Server: nginx

Date: Sun, 21 Jun 2026 12:51:34 GMT

Content-Type: text/html

Content-Length: 15800

Last-Modified: Sun, 21 Jun 2026 10:41:49 GMT

Connection: keep-alive

ETag: "6a37bfed-3db8"

Accept-Ranges: bytes

`curl http://localhost:7000 -I`

HTTP/1.1 301 MOVED PERMANENTLY

Server: gunicorn

Date: Sun, 21 Jun 2026 12:52:41 GMT

Connection: keep-alive

Content-Type: text/html; charset=utf-8

Content-Length: 199

Location: /login

Content-Security-Policy: object-src 'none'; frame-ancestors 'self'; default-src https: http: 'self' https://www.bunkerweb.io https://assets.bunkerity.com https://bunkerity.us1.list-manage.com https://api.github.com; script-src https: http: 'self' 'nonce-GMs-o8dnvNagzv8S9d7vautZUClpsfQbLfoxCcqy55k' 'strict-dynamic' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https://www.bunkerweb.io https://assets.bunkerity.com https://*.tile.openstreetmap.org; font-src 'self' data:; base-uri 'self'; block-all-mixed-content; connect-src https: http: 'self'

https://api.github.com/repos/bunkerity/bunkerweb
https://www.bunkerweb.io/api/posts/0/3;

X-Frame-Options: DENY

X-Content-Type-Options: nosniff

Referrer-Policy: strict-origin-when-cross-origin

Permissions-Policy: accelerometer=(), ambient-light-sensor=(), attribution-reporting=(), autoplay=(), battery=(), bluetooth=(), browsing-topics=(), camera=(), compute-pressure=(), display-capture=(), encrypted-media=(), execution-while-not-rendered=(), execution-while-out-of-viewport=(), fullscreen=(), gamepad=(), geolocation=(), gyroscope=(), hid=(), identity-credentials-get=(), idle-detection=(), local-fonts=(), magnetometer=(), microphone=(), midi=(), otp-credentials=(), payment=(), picture-in-picture=(), publickey-credentials-create=(), publickey-credentials-get=(), screen-wake-lock=(), serial=(), speaker-selection=(), storage-access=(), usb=(), web-share=(), window-management=(), xr-spatial-tracking=(), interest-cohort=()

Vary: Cookie

```
curl http://localhost:11334 -I
```

HTTP/1.1 500 Invalid method

Connection: close

Server: rspamd/3.12.1

Date: Sun, 21 Jun 2026 12:53:32 GMT

Content-Length: 0

Content-Type: text/plain

Cache-Control: no-store

- Нормально - из интернета доступны серверы DMZ

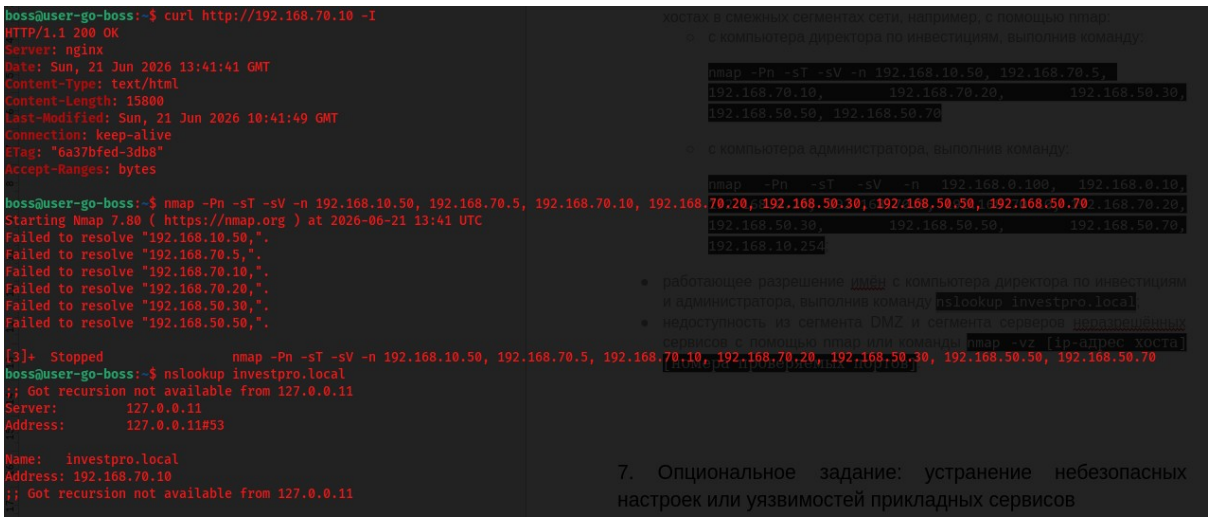
4. Доступность сервисов внутри сети

Для подтверждения сетевой доступности и работоспособности сервисов допустимо использовать как netcat с указанием конкретных портов, так и другие утилиты: nmap, curl и так далее, а также браузер, почтовый клиент или файловый менеджер.

После применения правил МСЭ добавьте скриншоты, демонстрирующие:

- доступность основных сервисов, описанных в таблице выше, на всех хостах в смежных сегментах сети, например, с помощью nmap:
    - с компьютера директора по инвестициям, выполнив команду:

```
nmap -Pn -sT -sV -n 192.168.10.50, 192.168.70.5, 192.168.70.10, 192.168.70.20, 192.168.50.30, 192.168.50.50, 192.168.50.70
```



Я что то не понимаю, так же и должно быть, что боссу недоступен ssh и nmap, но при этом доступен сайт и резолвится адрес `nslookup investpro.local`;

    - с компьютера администратора, выполнив команду:

```
nmap -Pn -sT -sV -n 192.168.0.100, 192.168.0.10, 192.168.0.20, 192.168.70.5, 192.168.70.10, 192.168.70.20, 192.168.50.30, 192.168.50.50, 192.168.50.70, 192.168.10.254;
```

- работающее разрешение имён с компьютера директора по инвестициям и администратора, выполнив команду `nslookup investpro.local`;
- недоступность из сегмента DMZ и сегмента серверов неразрешённых сервисов с помощью nmap или команды `nmap -vz [ip-адрес хоста] [номера проверяемых портов]`.

- При всем моем “большом” уважении к инфраструктуре яндекса, у меня с какого момента перестала нормально работать ВМ, я ее перезупаскал, но на финальном этапе я просто не смог установить nmap на комп админа, потому что вм дико лагает и не коннектится, паки просто не скачиваются.

В правилах nftables прописан доступ users,admin к интернету, не понимаю, я вроде все правильно сделал.

7. Опциональное задание: устранение небезопасных настроек или уязвимостей прикладных сервисов

- Если вы выполнили дополнительные настройки и действия по обеспечению безопасности инфраструктуры, добавьте в этот раздел скриншоты, выводы команд или конфигурационные файлы, подтверждающие их реализацию.
- Добавьте поясняющий комментарий, почему выполнены именно эти настройки и действия.

Комментарии

Прочитай пожалуйста часть 6 пункт 4, так все и должно быть, или я где то накосячил??